

Pramo Jewels

AI Security Guide

Document ID: PJ-AISG-001
Version: 1.0
Status: Approved

Field	Value
Project	Pramo Jewels Premium E-Commerce Platform
Purpose	Define security standards and practices for AI-assisted software development.
Audience	Developers, Security Engineers, AI Coding Assistants, Architects, QA
Version	1.0

AI Security Standards

Security Area	Guidelines
Authentication	Use secure authentication and RBAC for all protected resources
Input Validation	Validate and sanitize all external input
Secrets	Never hard-code credentials; use secure secret management
Encryption	Encrypt sensitive data in transit and at rest
API Security	HTTPS, rate limiting, token validation and secure headers
Dependency Security	Use trusted libraries and regularly scan dependencies
Logging	Maintain audit logs without exposing sensitive information
Testing	Perform security testing before deployment

Objectives

Ensure AI-generated code complies with project security policies and industry best practices while minimizing security risks.

Secure Development Rules

Follow least-privilege principles, validate inputs, implement output encoding, avoid insecure defaults and review AI-generated code before use.

Threat Prevention

Protect against SQL Injection, XSS, CSRF, SSRF, insecure deserialization, broken access control and other common application threats.

Data Protection

Classify sensitive data, minimize collection, enforce encryption, protect personal information and comply with organizational privacy requirements.

Security Review

Run static analysis, dependency scanning, vulnerability assessment and manual security review before approving AI-generated changes.

Incident Handling

Document security findings, prioritize remediation, retest fixes and maintain complete audit trails for security-related changes.

Integration

Integrates with Authentication, API Gateway, Monitoring, Audit Logging, CI/CD Security Scans, Secrets Management and Incident Management.

Acceptance Criteria

AI-generated code passes security reviews, vulnerability scans, penetration testing requirements and complies with the project's security standards.